

Plantilla de Reporte Ejecutivo (estilo PowerPoint) – Encuesta ISO 27001

A continuación se propone una estructura de presentación para comunicar los resultados de la encuesta a comités de dirección, consejos y otros foros ejecutivos.

Cada sección corresponde a una diapositiva (o conjunto de ellas). El contenido se puede trasladar a PowerPoint, Keynote o herramientas similares.

Diapositiva 1 – Título

- Título: Estado de los indicadores y métricas de ciberseguridad (ISO 27001)
- Subtítulo: Resultados de la encuesta en [nombre de sector / ámbito]
- Datos: Fecha, entidad responsable, logos relevantes.

Diapositiva 2 – Contexto y objetivos

- Objetivo: resumir el propósito de la encuesta y su alcance.
- Puntos clave:
- Evaluar cómo se diseñan y utilizan indicadores de seguridad alineados con ISO/IEC 27001:2022. [web:1][web:33]
- Analizar integración con requisitos regulatorios (NIS2, GDPR, marcos nacionales). [web:22][web:20]
- Proporcionar una base para decisiones de mejora y priorización de inversiones.

Diapositiva 3 – Metodología (resumen)

- Tipo de encuesta (online, auto-administrada).
- Población objetivo (CISOs, responsables de riesgos, etc.).
- Número de organizaciones participantes, sectores cubiertos, tamaño.
- Referencias normativas y de buenas prácticas (ISO 27001/27004, ISACA, ENISA). [web:13][web:16]

Diapositiva 4 – Perfil de la muestra

- Gráficos sugeridos:
- Distribución por tipo de organización (pública, privada, operador esencial, etc.).
- Distribución por sector (sanitario, energía, banca, etc.).
- Notas interpretativas breves sobre la representatividad.

Diapositiva 5 – Índice Global de Madurez (IGM)

- Presentar el IGM medio y su distribución (mínimo, máximo, cuartiles).
- Visualizaciones:
- Gráfico de barras o caja y bigotes.
- Semáforo de nivel medio (1–5).
- Mensaje clave: en qué nivel se sitúa globalmente el sistema de indicadores de las organizaciones estudiadas.

Diapositiva 6 – Subíndices por bloque

- Mostrar resultados por bloques principales:
- Gobernanza y metodología.
- Riesgos.
- Técnicos / vulnerabilidades.
- Incidentes / SOC.
- Concienciación.
- Resiliencia.
- Regulación.
- Utilizar gráfico tipo radar o barras comparativas.
- Resaltar las 2–3 áreas más fuertes y las 2–3 más débiles.

Diapositiva 7 – Gobernanza y uso de indicadores

- ¿Cuántas organizaciones tienen sistema formal de indicadores aprobado?
- ¿Con qué frecuencia se revisan en órganos de gobierno?
- ¿Influyen en decisiones de inversión?
- Mensaje narrativo: grado de institucionalización de la medición.

Diapositiva 8 – Riesgos y controles técnicos

- Resultados clave:
- % de organizaciones con KRIs definidos y usados.
- Nivel de uso de métricas de vulnerabilidades y patching.
- Posibles visualizaciones:
- Gráfico comparando adopción de KPIs de riesgos vs. técnicos.
- Mensaje: dónde se concentra la medición y qué áreas están menos cubiertas.

Diapositiva 9 – Incidentes, SOC y resiliencia

- Estadísticas sobre:
- Indicadores de incidentes (MTTD, MTTR, SLA, reincidencia).
- Existencia de KPIs para SOC y capacidades de detección avanzada.
- Indicadores de continuidad (RTO/RPO, pruebas). [web:16][web:12]
- Relación con tendencias nacionales (incremento de incidentes, etc.). [web:12][web:36]

Diapositiva 10 – Concienciación y comportamiento

- Nivel de uso de:
- KPIs de formación (cobertura, resultados).
- Métricas de campañas de phishing simulado.
- Conclusiones rápidas sobre cultura de seguridad y métricas asociadas.

Diapositiva 11 – Regulación y benchmarking

- Grado de alineamiento percibido con NIS2, GDPR y otros marcos.
- Uso de datos de INCIBE, ENISA y organismos similares como benchmarks. [web:12][web:16][web:20]
- Mensaje: en qué medida las métricas internas están conectadas con el contexto externo.

Diapositiva 12 – Automatización y calidad de datos

- Porcentaje de organizaciones con alta automatización de la recogida de datos.
- Evaluación de la calidad de los datos (formal, informal, inexistente).
- Riesgos y oportunidades asociados (por ejemplo, “indicadores sofisticados apoyados en datos dudosos”).

Diapositiva 13 – ROI y visión económica

- Presentar resultados de ROI de seguridad, si se han calculado (media, dispersión). [web:4][web:13]
- Otros indicadores económicos: coste por incidente, coste por punto de IGM, etc.
- Mensaje: hasta qué punto se está traduciendo la seguridad a un lenguaje económico comprensible para la dirección.

Diapositiva 14 – Áreas de mejora prioritarias

- Basándose en los resultados, proponer 3–5 líneas de acción:
- Fortalecer el diseño metodológico de KPIs.
- Mejorar medición de resiliencia y terceros.
- Incrementar automatización y calidad de datos.
- Integrar indicadores con marcos regulatorios y de riesgo empresarial.
- Enfatizar que son recomendaciones, no sentencias.

Diapositiva 15 – Hoja de ruta sugerida

- Plantear una hoja de ruta en 3 horizontes:
- Corto plazo (0–6 meses): limpieza y racionalización de indicadores, quick wins.
- Medio plazo (6–18 meses): automatización, integración con GRC, refuerzo de KPIs críticos.
- Largo plazo (> 18 meses): métricas avanzadas, análisis predictivo, integración plena con decisiones de negocio.

Diapositiva 16 – Cierre

- Mensaje final:
- Importancia de medir bien para gestionar bien.
- Relevancia en el contexto de amenazas crecientes y exigencias regulatorias. [web:16][web:22]
- Espacio para preguntas, comentarios y, con algo de suerte, decisiones concretas.